

Practical File / Case Study

On

## **BLOCKCHAIN POLICY**

### **Blockchain Security: Technology vs. Human Error**

Submitted in partial fulfilment of the requirements for  
the award of the degree

**Bachelor of Technology**

in

**Department of Computer Science and Engineering**



**Submitted to:**

Ms. Bisma

Faculty

CSE / SOET

**Submitted by:**

Harshit Khemani

241302081

B.Tech CSE (AI/ML)

Section - C

5th Semester

School of Engineering and Technology

Department of CSE

**SGT University**

# CONTENTS

Abstract

1. Introduction

2. Background: How Blockchain Security Is Supposed to Work

3. The Human Layer: Where Most Value Is Actually Lost

4. Real-World Cases

5. Technology versus Human Error — A Structured Comparison

6. Policy Discussion

7. Recommendations

8. Conclusion

References

# ABSTRACT

Public blockchains are often described as “unhackable” because they replace trusted intermediaries with cryptography, replication, and economic incentives. That claim is only half true. The consensus layer of Bitcoin, Ethereum, and similar networks has proven remarkably resistant to cryptographic break and protocol-level takeover. The losses that dominate headlines — stolen keys, phished seed phrases, drained bridges, compromised validators, and collapsed exchanges — almost always sit one layer above the ledger. They are failures of people, organisations, and interfaces, not of SHA-256 or elliptic-curve signatures. This case study separates *protocol security* from *operational security*. It reviews how blockchain security is designed to work, maps the human-error surface (key custody, social engineering, insider risk, rushed upgrades, and governance theatre), and examines incidents from Mt. Gox and The DAO through Ronin, FTX, and later bridge and exchange compromises. The policy argument is that treating every loss as a “blockchain hack” produces the wrong law. India and other jurisdictions should regulate custody, exchanges, and consumer interfaces as they would any other high-value financial channel, while leaving the base protocol’s openness intact. Technology can raise the cost of attack; it cannot abolish human error. Policy that ignores that distinction either over-regulates the ledger or under-regulates the people who hold the keys.

**Keywords:** blockchain security; private keys; human error; custody; smart-contract risk; exchange failure; operational security; India crypto policy.

## 1. Introduction

Every few months a large theft is reported as proof that “blockchain is not secure.” The wording is convenient for headlines and unhelpful for policy. A blockchain is a replicated state machine whose security claim is narrow: honest-majority consensus plus collision-resistant hashing plus unforgeable digital signatures. If those assumptions hold, rewriting confirmed history is expensive and forging a payment without a private key is infeasible with known algorithms. That is a genuine engineering achievement. It is also not the same thing as saying that users, exchanges, bridges, or companies that touch the chain cannot be robbed.

The distinction matters because the two failure modes imply different remedies. A cryptographic break of ECDSA, or a sustained 51 percent attack on a major proof-of-work or proof-of-stake network, would be a technology crisis. It would justify protocol changes, perhaps even a coordinated hard fork, and it would force every wallet and custodian to migrate. A support agent who is socially engineered into approving a withdrawal, a founder who keeps exchange reserves in a hot wallet, or a user who pastes a seed phrase into a fake “verification” site is a human-systems crisis. The ledger did exactly what it was told. The signature was valid. The policy question is who was allowed to hold the key, how they were trained, and what duty of care the law imposes on that custodian.

This paper takes that split as its organising idea. Section 2 restates the security model that blockchain designers actually claim — not the marketing version. Section 3 catalogues the human layer: key management, phishing, insiders, rushed governance, and the interface between code and people. Section 4 walks through real incidents chosen because each one is still mis-described in public debate. Section 5 compares technology risk and human-error risk on the same axes (frequency, loss size, who can fix it, and what law can usefully do). Section 6 turns to policy in India and in the jurisdictions India copies from — the European Union’s Markets in Crypto-Assets regime, United States custody and exchange rules, and FATF guidance on virtual-asset service providers. Section 7 offers recommendations that a fifth-semester

engineering student can defend in viva: regulate custody and consumer interfaces; require audits and disclosure where code is the product; do not pretend that banning self-custody or “fixing” public ledgers will stop people from being tricked.

The audience is undergraduate. The paper does not invent a new cryptographic primitive. It does insist that Computer Science students who will later write wallets, exchanges, or policy briefs stop treating “the chain was hacked” as a single category. If the category is wrong, the statute will be wrong.

## **2. Background: How Blockchain Security Is Supposed to Work**

### **2.1 The narrow security claim**

Nakamoto’s design (2008) combined a peer-to-peer timestamp server, proof-of-work, and the longest-chain rule so that participants who do not trust one another can still agree on an order of transactions. Ethereum generalised the same idea to a virtual machine. Later proof-of-stake systems replaced energy expenditure with locked capital and slashing. The security claim in all of these designs is not “nobody can ever lose money.” It is closer to: an attacker who does not control a decisive share of hashrate or stake, and who does not possess a user’s private key, cannot quietly rewrite history or spend that user’s coins.

Three technical properties do the work. First, hash-linked blocks make tampering with an old record visible because every later header would change. Second, digital signatures bind spending authority to a secret. Third, consensus makes it costly to publish an alternative history that the honest majority will accept. National Institute of Standards and Technology guidance on blockchain (NISTIR 8202) is careful on this point: distributed ledgers can provide integrity and non-repudiation of recorded state; they do not, by themselves, authenticate the human being who authorised a transaction or guarantee that the software around the ledger is free of bugs.

### **2.2 What the protocol does not promise**

A confirmed transaction is final in the protocol sense. It is not reversible by a helpdesk. That property is a feature against chargeback fraud and a hazard against theft. Once a signature is broadcast, the network has no concept of “the real owner changed their mind” or “this key was stolen last Tuesday.” Irreversibility moves the entire burden of authentication onto whatever process produced the signature — a hardware wallet prompt, an exchange withdrawal workflow, a multisig ceremony, or a smart-contract call constructed by a front-end. If that process is compromised, the chain will faithfully settle the attacker’s intent.

Smart contracts add a second non-promise. On-chain code is transparent and often immutable. Transparency helps auditors; immutability means a bug is a permanent public exploit. The 2016 DAO split on Ethereum is the canonical reminder that “code is law” is a slogan, not a security theorem. The virtual machine executed the re-entrancy pattern correctly. The humans who wrote and funded the contract had not imagined that pattern. Technology did not fail in the cryptographic sense. Specification and review failed.

### **2.3 Layers that actually get attacked**

Practitioners already think in layers, even when public debate does not. A useful undergraduate map is:

| Layer                   | What can fail                                     | Typical attacker                              | Who can patch it                 |
|-------------------------|---------------------------------------------------|-----------------------------------------------|----------------------------------|
| Consensus / protocol    | 51% rewrite, consensus bug, crypto break          | Nation-state or well-capitalised miner/staker | Core developers + node operators |
| Client software         | Implementation bug, eclipse attack, RPC spoof     | Skilled remote attacker                       | Client teams                     |
| Smart contract / bridge | Logic bug, oracle manipulation, upgrade key theft | Specialised exploit teams                     | Project team (if upgradeable)    |
| Custody / exchange      | Hot-wallet drain, insider, poor cold-storage      | Criminals + insiders                          | The firm and its regulator       |
| User / interface        | Phishing, malware, fake apps, seed-phrase leakage | Industrialised scam operations                | User, wallet vendor, platforms   |

*Table 1. Security layers around a public blockchain. Most recorded value loss sits in the bottom three rows.*

Chainalysis and other commercial crime reports, year after year, show the same shape: protocol-level failures of Bitcoin or Ethereum are rare; service compromises, DeFi exploits, and scams are common. The technology stack at the bottom of Table 1 is not the main loss channel. Policy that only “secures the blockchain” is therefore aimed at the wrong row.

### 3. The Human Layer: Where Most Value Is Actually Lost

#### 3.1 Keys are people, not mathematics

A private key is a large random number. In textbooks it is an abstract object. In life it is a seed phrase written on paper, stored in a password manager, split across three executives, or held by a custodian’s hardware security module. Every one of those representations reintroduces a human process. Paper burns and is photographed. Password managers are phished. Executives travel, fall out, or are coerced. HSMs are configured by engineers who can be bribed or who leave a debug path open. The cryptography did not get weaker. The mapping from “possessor of the secret” to “intended owner” got messy.

Self-custody is therefore not a moral virtue by default. It is a risk-transfer decision. The user accepts operational burden in exchange for removing exchange insolvency risk. That bargain is honest only if the user can actually perform operational security — backups, device hygiene, and the discipline not to type a seed phrase into a website. Many cannot. Policy that celebrates self-custody without consumer-protection education simply moves losses from firms the state can supervise onto individuals the state will later be asked to compensate through other means.

#### 3.2 Social engineering scales better than cryptanalysis

Breaking secp256k1 with a classical computer is not a practical criminal business model. Convincing a human that a support agent needs their seed phrase is. Phishing kits, cloned wallet-connect pages, fake mobile apps, and “ice phishing” (tricking a user into signing an approval that drains tokens) industrialise that insight. The attacker does not need a novel zero-day in the virtual machine. They need a plausible domain name, a stolen brand kit, and a tired user. Approval phishing on Ethereum-style chains is especially ugly because the victim’s signature is valid: they authorised an unlimited token allowance to a contract they did not read.

This is not unique to crypto. Banking already fights authorised-push-payment fraud. The difference is recovery. A bank can sometimes reverse a transfer. A public chain cannot. Human-error losses are

therefore more final, which is why they feel like technology failures even when they are not.

### **3.3 Organisations fail like organisations**

Exchanges, bridges, and “decentralised” projects still have chat tools, on-call rotations, cloud accounts, and privileged signing keys. The Ronin bridge compromise (2022) was not a break of Ethereum or of Axie Infinity’s game logic. It was a validator-key compromise obtained in part through social engineering of a project employee, combined with a signing threshold that was too low. FTX (2022) was not a consensus failure of Solana or Bitcoin. It was commingling, missing controls, and alleged fraud — the oldest story in finance, wearing a new logo. When a bridge upgrade key or an exchange cold-wallet ceremony is the real control plane, the system’s security is the security of that ceremony.

Insider risk is systematically under-discussed in student essays that focus on “51 percent attacks.” A single privileged engineer, or a founder who can move customer assets, is a more plausible threat than a sudden majority of Bitcoin hashrate. Technology (multisig, timelocks, proof-of-reserves with liabilities, hardware isolation) can shrink that insider surface. It cannot remove the need for independent people who refuse to sign a bad transaction. That refusal is a human control.

### **3.4 Speed, complexity, and the illusion of decentralisation**

Human error loves complexity. A twelve-step bridge UI, an “approve / swap / stake” flow that hides a delegatecall, or a governance vote held over a weekend will produce mistakes even among competent users. Teams under pressure ship unaudited upgrades. DAOs vote with low turnout. The word decentralised is then used as a shield: if no one is in charge, no one is responsible. Policy should be allergic to that shield. If a small set of keys or a small set of people can halt a bridge, upgrade a contract, or unlock a treasury, those people are operators. Operators have duties.

## **4. Real-World Cases**

The following cases are chosen because each one is still used, incorrectly, as evidence about “whether blockchain works.” Read together, they show that the ledger’s cryptographic core survived every incident; the humans and firms around it did not.

### **4.1 Mt. Gox (2011–2014): custody without a control culture**

Mt. Gox was, for a time, the dominant Bitcoin exchange. It failed after years of poor key hygiene, disputed transaction-malleability issues, and an inability to reconcile customer balances with on-chain reserves. Bitcoin the protocol continued. The lesson that should have been permanent — and was not — is that an exchange is a bank-shaped institution. It needs segregation of customer assets, dual control over withdrawals, independent audit, and a regulator who can revoke a licence when those controls are theatre. Japan later built a registration regime for crypto exchanges precisely because Mt. Gox demonstrated that the technology’s integrity does not automatically produce institutional integrity.

### **4.2 The DAO (2016): the contract did what it was told**

The DAO raised a then-unprecedented sum into an Ethereum smart contract that was intended to govern investment decisions. A re-entrancy bug allowed an attacker to drain a large fraction of the funds. The Ethereum community controversially hard-forked to restore the pre-attack state, creating Ethereum Classic as the chain that refused the fork. Two policy points follow. First, immutability is a choice, not a law of nature: when losses are large enough, humans will renegotiate “finality.” That renegotiation is governance,

and it is human. Second, treating the incident as a failure of blockchain cryptography is illiterate. The virtual machine was consistent. The specification was incomplete. The right instruments are mandatory disclosure of audit scope, bug-bounty norms, and — where a contract holds public savings-like funds — a pause-and-upgrade path that is itself disclosed and access-controlled.

### 4.3 Parity wallet freeze (2017): one user’s mistake, many victims

A user accidentally triggered a function that killed a library contract underlying many Parity multi-signature wallets, freezing a large amount of ether. This is human error in the most literal sense: a privileged call that should never have been exposed in that way, executed by someone who did not intend the consequence. The technology “worked.” The dependency design did not. Shared libraries with suicide/self-destruct semantics are an engineering smell. They are also a warning for policymakers who want a single on-off switch for the industry: concentrated upgrade keys and shared libraries create systemic risk that looks technical and is organisational.

### 4.4 Ronin bridge (2022): social engineering of validators

The Ronin bridge secured assets for a popular play-to-earn game by a small validator set. Attackers compromised validator keys — including through social engineering of a Sky Mavis employee — and minted withdrawals far beyond what a healthy bridge should have allowed. The economic damage was among the largest in DeFi history at the time. Ethereum’s consensus was irrelevant. The bridge was a centralised custodian wearing a validator costume. Policy should look through the costume. If nine people (or five, or four) can steal a billion dollars, the entity is a financial market infrastructure and should face the controls that apply to one: minimum validator diversity, key-ceremony standards, incident reporting, and capital or insurance against operational loss.

### 4.5 FTX (2022): fraud and governance, not a chain rewrite

FTX’s collapse destroyed customer claims through commingling, related-party lending, and the absence of basic controls — not through a break of any layer-one blockchain. It is included here because public rhetoric still collapses “crypto failed” into one bucket. For a policy case study the bucket must be split. Proof-of-reserves without proof-of-liabilities is insufficient. Related-party exposure must be visible to an examiner. Customer assets must be bankruptcy-remote. None of those requirements needs a new hash function. All of them need humans who can be punished when they lie.

### 4.6 Industrialised phishing and fake applications (ongoing)

Retail loss in India and elsewhere is now dominated by cloned apps, Telegram “recovery agents,” fake airdrops, and romance-to-investment funnels that end in a deposit address. CERT-In advisories and Indian cybercrime reporting portals document the pattern repeatedly. The victim authorises the transfer. The chain settles it. A statute that only criminalises “hacking a blockchain” will miss the offence, which is fraud and unauthorised access to the victim’s device or attention. The useful tools are platform liability for app stores, domain takedown with due process, bank-side friction on mule accounts, and mandatory warnings in wallet software when a user is about to sign a dangerous approval.

| Incident | Public story        | Better description       | Primary fix                    |
|----------|---------------------|--------------------------|--------------------------------|
| Mt. Gox  | Bitcoin was hacked  | Exchange custody failure | Licensing, audits, segregation |
| The DAO  | Ethereum was hacked | Unaudited contract logic | Audit, bounty, disclosed pause |

| Incident             | Public story     | Better description                  | Primary fix                       |
|----------------------|------------------|-------------------------------------|-----------------------------------|
| Parity freeze        | Wallets broke    | Shared-library design + human call  | Safer defaults, no suicide libs   |
| Ronin                | Bridge hack      | Validator keys + social engineering | Thresholds, diversity, opsec      |
| FTX                  | Crypto collapsed | Fraud and missing controls          | Custody law, examiners            |
| Phishing / fake apps | Wallet hack      | Authorised fraud                    | UI warnings, platforms, education |

Table 2. How incidents are narrated versus what actually failed.

## 5. Technology versus Human Error — A Structured Comparison

It is possible to be precise without being simplistic. Technology risk is real. Consensus bugs have occurred on smaller chains. Hash-function migration will eventually be required if large-scale quantum computers arrive. Client diversity on Ethereum is itself a response to implementation risk. Bridge contracts concentrate unprecedented value in a few thousand lines of Solidity. None of that is imaginary. The claim of this paper is about *relative* frequency, relative loss, and relative policy leverage — not about a fairy-tale protocol.

### 5.1 Frequency and magnitude

Protocol-level failures of the two largest networks are rare enough that each one would be a global news event and a research paper. Human-layer failures are daily. A single phishing campaign can harvest more seed phrases in a week than a decade of published consensus CVEs has moved in value. Magnitude is more mixed: a badly designed bridge can lose more in one transaction than a thousand phishing victims combined. That is still not an argument that “the blockchain is insecure.” It is an argument that concentrated operational keys are a systemic-risk object and should be supervised like one.

### 5.2 Detectability and attribution

On-chain, theft is often visible: the destination address is public. Attribution to a human is not. Mixers, chain-hopping, and unhosted wallets complicate recovery. This produces a political temptation to ban privacy tools or self-custody. The temptation should be resisted as a first response, because it punishes the security model (user-held keys) in order to paper over the investigation problem. Better levers are travel-rule obligations on *service providers*, analytics partnerships that already exist in Indian enforcement, and mutual legal assistance — not a fantasy that the protocol can identify a person the way a bank KYC file can.

### 5.3 Who can reduce the risk

Core developers can patch clients and design safer account abstractions (social recovery, spending limits, session keys). Wallet vendors can simulate transactions and warn on infinite approvals. Exchanges can enforce withdrawal allow-lists and cooling-off periods. App stores can remove clones. Universities can teach operational security as part of the same course that teaches Merkle trees. Legislatures can impose duties on custodians. Almost none of these actors need to change the Bitcoin or Ethereum consensus rules to make users safer next year. That is the practical meaning of “human error is the larger problem.”

### 5.4 A fair objection



A fair objection is that drawing a hard line between technology and humans is itself a design failure: good systems assume fallible people. Donald Norman’s classic human-error work and the later safety literature (Reason’s Swiss-cheese model) say the same thing in aviation and medicine. If a wallet UI makes the dangerous action the easy action, the resulting loss is a product defect, not a moral failing of the user. This paper accepts the objection. “Human error” here includes poorly designed human–computer interfaces and poorly governed organisations. It does not mean “blame the victim.” It means: the residual risk after cryptography has done its job is still mostly a people-and-process risk, and that is where policy has leverage.

## **6. Policy Discussion**

### **6.1 The wrong statute**

Indian public debate has periodically proposed bans, blanket taxation without a licensing framework, or language that treats all virtual-digital-asset activity as inherently suspect. The 30 percent tax on transfers of virtual digital assets and the 1 percent TDS under the Income-tax Act are facts of the current regime; they are not a security policy. A security policy would answer different questions. Who may hold customer keys? What incidents must be reported to CERT-In and to a financial supervisor? What minimum controls apply to an INR on-ramp? What must a wallet disclose before a first-time user signs a contract interaction? Those questions are closer to the Reserve Bank’s operational-risk thinking for payment systems than to a debate about whether SHA-256 is safe.

### **6.2 What other jurisdictions got right — and overdid**

The European Union’s Markets in Crypto-Assets Regulation (MiCA) is useful because it regulates issuers and service providers, not the public protocol. Custody, exchange, and advice become licensable activities with capital, governance, and white-paper duties. That is the correct target if one believes this case study. The United States has used enforcement (exchange registrations, custody statements by banking agencies, actions against unregistered platforms) more than a single statute; the result is uneven but still aimed at intermediaries. FATF Recommendation 15 and the Travel Rule push virtual-asset service providers to identify counterparties on transfers. Again, the obligated party is a business, not a hash function.

Overreach appears when regulation tries to make the base layer identify users, or when a mixer or privacy tool is treated as equivalent to a custodial exchange. There are legitimate AML concerns. There is also a security reason to allow people to hold keys: a world in which every wallet is an account at a licensed firm is a world with a smaller number of richer honeypots — exactly the Mt. Gox / FTX failure mode. Policy should raise the cost of running a sloppy custodian without making self-custody a crime.

### **6.3 India’s institutional map**

Several Indian institutions already touch the problem without owning it. The Ministry of Electronics and Information Technology and CERT-In see incidents. The Financial Intelligence Unit sees suspicious-transaction reports from the entities that are reporting. The Reserve Bank cares about banking channels and has historically been hostile to a private INR-crypto rail. The Securities and Exchange Board of India would be the natural home if a token is a security; many tokens are not cleanly so. The result is a gap: retail users lose funds to phishing and unregistered platforms, while no single supervisor writes custody standards comparable to those for depositories or payment banks. Filling that gap does not require India to “adopt blockchain” as industrial policy. It requires India to admit that a large unofficial market

already exists and that its losses are mostly operational.

## 6.4 Education is a security control

Engineering colleges still teach cryptography as mathematics and security as network attacks. Few courses force a student to recover a wallet from a seed phrase, to read an Etherscan approval, or to explain why a hardware wallet confirmation is the last line of defence. If human error is the dominant loss channel, then curriculum is critical infrastructure. SGT's own framing of this assignment as *Blockchain Policy* rather than only *Blockchain Technology* is the right instinct. A graduate who can implement a Merkle tree but cannot explain why FTX was not a 51 percent attack will write the wrong brief for a ministry.

## 6.5 Liability and the design of wallets

Product liability is the quiet policy tool. If a widely distributed wallet ships with a default that grants unlimited token approvals, or if an exchange app deep-links into a WebView that does not isolate session cookies, the resulting “user error” is foreseeable. Jurisdictions that already apply unfair-contract and product-safety thinking to software can extend it here without inventing crypto-exceptionalism. The aim is not to make developers insurers of every phishing victim. It is to make the dangerous default more expensive to ship than the safe one.

## 7. Recommendations

The recommendations below are scoped to what a national government, a university, and a reasonably competent exchange or wallet team can do in the next few years. They are not a protocol upgrade roadmap.

### 7.1 For Indian policymakers

- **Licence custody, not the ledger.** Create a virtual-asset service-provider category with fit-and-proper tests, segregation of customer assets, independent audit, withdrawal dual-control, and incident reporting to CERT-In and a financial supervisor. Leave public-network validation legal.
- **Write operational-risk standards, not cryptographic ones.** Borrow from RBI IT and operational-risk circulars: key-ceremony documentation, HSM use, maker-checker, penetration testing, and board-level ownership of wallet architecture.
- **Force look-through on “decentralised” bridges and wrappers** that in fact have upgrade keys or small validator sets. If a room of people can steal the float, they are intermediaries.
- **Do not criminalise self-custody.** Require education and risk warnings at on-ramps instead. Banning unhosted wallets concentrates honeypots.
- **Coordinate FIU-IND, CERT-In, MeitY, RBI, and SEBI** on a single incident taxonomy so a phishing drain is not filed as a “blockchain hack” in one office and “cyber fraud” in another.

### 7.2 For exchanges, bridges, and wallet vendors

- Default to hardware-backed cold storage for the large majority of assets; publish a proof-of-reserves and a proof-of-liabilities design.
- Simulate unsigned transactions in the UI; block or warn on unlimited approvals and unknown delegatecalls.

- Enforce withdrawal allow-lists, delays for new devices, and out-of-band confirmation that is not SMS-only.
- Run phishing-resistant authentication (FIDO2) for internal tools. Ronin is a warning about Slack and passwords as the real root of trust.
- Fund bug bounties that pay more than a quiet exploit sale, and disclose the scope of any audit — what was out of scope is as important as the logo.

### 7.3 For universities and this course

- Teach key-management labs beside consensus labs. A student should lose a practice wallet once, on purpose, and write up the recovery failure.
- Require case write-ups that classify each public incident using Table 1 before any normative claim about “banning crypto” or “trusting the chain.”
- Invite a CERT-In or FIU practitioner for one session on mule accounts and on-ramp typology, so policy discussion is not only white-paper theory.

### 7.4 What not to do

Do not mandate a backdoor in every wallet. Do not require every node operator to KYC peers. Do not treat a successful phishing campaign as evidence that Merkle trees failed. Those responses confuse the rows of Table 1 and will either be ignored by the market or will create a smaller number of larger, more official failures.

## 8. Conclusion

Blockchain security, as advertised, is a statement about mathematics, replication, and incentives. Blockchain security, as lived, is a statement about who holds a secret, who they trust, and how an organisation behaves at 2 a.m. when a withdrawal looks strange. The last decade of losses is lopsided. The base protocols of the major networks did not suffer a cryptographic collapse. Users, bridges, and exchanges did suffer a long sequence of preventable operational failures, some of them criminal.

Policy that starts from that fact becomes almost conservative. It looks like the supervision of custodians, the product design of wallets, the education of users, and the honesty of incident taxonomies. It does not look like a project to make the public ledger identify every citizen or to declare the technology itself unsafe. Technology can raise the cost of the next attack — account abstraction, better simulations, safer defaults, client diversity, quantum-ready signatures when they are actually needed. Human error will remain. The adult response is to design for it and to regulate the humans and firms who concentrate other people’s keys, not to pretend that a better hash function would have saved Mt. Gox or FTX.

For this course the operational moral is simple. When the next large theft is reported, the first question is not “is blockchain broken?” The first question is “which row of the stack failed, and which human process was that row secretly depending on?” If Indian students and Indian draftspersons can keep those questions separate, Blockchain Policy will be a more honest subject than Blockchain Hype.

## References

Antonopoulos, A. M. (2017). *Mastering Bitcoin* (2nd ed.). O’Reilly Media.

- Buterin, V. (2014). *A next-generation smart contract and decentralized application platform* (Ethereum white paper).
- Chainalysis. (2023–2025). *Crypto Crime Reports*. Chainalysis.
- European Union. (2023). Regulation (EU) 2023/1114 on markets in crypto-assets (MiCA). *Official Journal of the European Union*.
- FATF. (2021). *Updated guidance for a risk-based approach to virtual assets and virtual asset service providers*. Financial Action Task Force.
- Government of India. (2022). Finance Act, 2022 (virtual digital asset taxation, including s. 115BBH and s. 194S). Ministry of Finance.
- Indian Computer Emergency Response Team (CERT-In). Advisories on cryptocurrency frauds and malicious mobile applications. Ministry of Electronics and Information Technology.
- Nakamoto, S. (2008). *Bitcoin: A peer-to-peer electronic cash system*. <https://bitcoin.org/bitcoin.pdf>
- National Institute of Standards and Technology. (2018). *Blockchain technology overview* (NISTIR 8202). U.S. Department of Commerce.
- Norman, D. A. (1983). Design rules based on analyses of human error. *Communications of the ACM*, 26(4), 254–258.
- Reason, J. (1990). *Human error*. Cambridge University Press.
- Sky Mavis / Ronin. (2022). Post-mortem of the Ronin validator compromise. Project disclosures and contemporary reporting.
- U.S. Department of Justice. (2023–2024). Filings and statements relating to the FTX / Alameda collapse and related prosecutions.
- Yaga, D., Mell, P., Roby, N., & Scarfone, K. (2018). See NISTIR 8202 above (canonical U.S. technical overview used in this paper).
- Zhou, L., Xiong, X., Ernstberger, J., et al. (2023). SoK: Decentralized finance (DeFi) attacks. *IEEE Symposium on Security and Privacy*.
- Meiklejohn, S., et al. (2013). A fistful of Bitcoins: Characterizing payments among men with no names. *IMC '13*.
- Atzei, N., Bartoletti, M., & Cimoli, T. (2017). A survey of attacks on Ethereum smart contracts. *POST 2017*, LNCS 10204.
- Reserve Bank of India. Various circulars on information technology and operational risk for regulated entities (used here as an analogy for custody controls, not as a crypto licence).
- Financial Intelligence Unit — India. Reporting guidance relevant to virtual-asset-related suspicious transactions, as applicable to Indian reporting entities.
- SGT University, School of Engineering and Technology, Department of CSE. Course framing for Blockchain Policy case studies, 5th Semester, B.Tech CSE (AI/ML), Section C.